INFORMATION SECURITY PROGRAM PORTFOLIO

Vantage Financial Technologies.

A consolidated, board-ready portfolio uniting governance, risk, Zero Trust architecture, incident response, and the FY27 compliance roadmap into a single coherent security program.

Document Owner: Office of the CISO
Classification: Confidential — Internal & Board Use
Version: 1.0 | **Issued:** October 2026
Review Cycle: Annual (next review October 2027)
Prepared for: Board Security & Technology Committee

FRONT MATTER

Document Control & How to Read This Portfolio

Provenance, version history, and reading guidance for this consolidated package.

Purpose of This Portfolio

This portfolio consolidates the four core artifacts of Vantage's information security program into one governed package: the **governance documentation** (Section 1), the **enterprise risk register** (Section 2), the **Zero Trust architecture and incident response plan** (Sections 3–4), and the **board briefing** (Section 5). A single-page **executive summary** precedes the body so that a first-time reader can understand the whole program without opening any individual section. Section 6 (Compliance Roadmap) and the appendices complete the package.

These artifacts were not authored in isolation. Every risk named in the board briefing is drawn from the register; every architecture decision traces to a register risk ID; and every capability the incident response plan assumes is operational today is funded and delivered by the roadmap timeline. Section 7 documents that traceability explicitly.

Version History

Version	Date	Author	Summary of Change
0.1	Aug 2026	GRC Analyst	Initial assembly of governance documents.
0.5	Sep 2026	Security Engineering	Added Zero Trust architecture and IR plan.
0.8	Sep 2026	Office of the CISO	Consolidated risk register; added board briefing.
1.0	Oct 2026	CISO	Final consistency review; executive summary; approved for board distribution.

How to Read This Document

If you have five minutes

Read the **Executive Summary** and the **Board Briefing** (Section 5). Together they state the posture, the top risks, and the investment asks.

If you are a reviewer or auditor

Read **Sections 1–2** for policy and risk, then **Section 7** (Consistency & Traceability) to verify that the four artifacts agree with one another.

> **A note on internal consistency**
>
> This portfolio is deliberately cross-referenced. Risk IDs (R-01…R-15) are the shared vocabulary linking the register, the architecture, the incident response plan, the roadmap, and the board briefing. If a control, playbook, or roadmap item is proposed anywhere in this document, it names the risk it mitigates.

Contents

Executive Summary 4

Section 1 — Governance Documentation 5

1.1 Information Security Policy (Master) 5
1.2 Access Control Policy 7
1.3 Data Classification & Handling Standard 8
1.4 Third-Party Risk Management Policy 9
1.5 Security Governance Structure & Roles 10
Section 2 — Enterprise Risk Register 11
Section 3 — Zero Trust Architecture 16
Section 4 — Incident Response Plan 21
Section 5 — Board Briefing 24
Section 6 — Compliance Roadmap (FY27) 27
Section 7 — Consistency & Traceability Review 29
Appendix A — Control Mapping (NIST CSF 2.0) 31
Appendix B — Glossary 32

EXECUTIVE SUMMARY

The Security Program on One Page

Everything a first-time reader needs to understand Vantage's security posture — without opening another section.

Executive Summary

Vantage Financial Technologies — Information Security Program Portfolio, v1.0, October 2026

15	6	$92M	Q2 FY27	$1.42M
REGISTER RISKS	HIGH RISKS	ARR PROTECTED	ISO 27001	FY27 ASK

Vantage is a $92M-ARR, cloud-native fintech platform that automates lending and payments for community banks, credit unions, and SMB lenders. Our ~480 employees run the business on AWS, processing personally identifiable information and tokenized cardholder data on behalf of regulated institutions. Customers do not merely buy our software — they extend their own regulatory obligations to us, so our security program exists to make that extension of trust safe, repeatable, and provable.

This portfolio is the program's single source of truth. Section 1 sets the governance foundation — a master security policy with supporting access-control, data-handling, and third-party policies. Section 2 is the enterprise risk register: fifteen scored risks (R-01 through R-15) that give the program a shared vocabulary and a defensible priority order. Sections 3 and 4 describe how we defend and how we respond — a Zero Trust architecture that removes implicit network trust, and a NIST SP 800-61-aligned incident response plan that assumes only the capabilities we actually operate today. Section 5 is the board briefing; Section 6 is the FY27 roadmap that funds the next stage.

Our posture is best described as "maturing and defensible." We hold a current SOC 2 Type II report, have moved 95% of endpoints under managed detection and response, and keep a signed forensic retainer on standby. Six risks remain rated High: phishing-driven account takeover (R-01), third-party/supply-chain compromise (R-02), cloud misconfiguration (R-04), data exfiltration of regulated data (R-07), inadequate detection and response (R-12), and exploitation of unpatched vulnerabilities (R-14). These are the same six risks the board briefing asks the Committee to accept and fund — each a line item in the register, not a rhetorical flourish.

The program is coherent by construction. Every architecture decision in Section 3 traces to a specific risk ID, every incident-response assumption is a capability the roadmap already funds, and the board briefing cites only risks the register contains. Section 7 documents this traceability so a reviewer can verify it rather than take it on faith.

What we are asking for. The FY27 roadmap requests **$1.42M** to close the six High risks, achieve ISO 27001 certification by Q2 FY27, and advance toward PCI DSS v4.0 alignment. The most consequential ask is a third security engineer and a threat-hunting capability, because detection and response capacity — not tooling — is the binding constraint on reducing our highest risks. The program is sound, the priorities are evidence-based, and the investment closes a specific, named, measurable set of gaps.

One-sentence summary

Vantage runs a maturing, standards-anchored security program with six clearly identified high risks; this portfolio proves the governance, architecture, response, and funding all point at the same six risks — and asks the board to fund the FY27 roadmap that closes them.

SECTION 1

Governance Documentation

The policy foundation that translates board intent into enforceable, auditable rules for the whole organization.

Governance is where a security program stops being a set of technical preferences and becomes an obligation the organization can be held to. The documents in this section are the program's constitution: they state what Vantage protects, who is accountable, and which behaviors are mandatory. They are written to be testable — every clause maps to a control an auditor can verify — and they deliberately use the same risk vocabulary (R-01…R-15) as the register so that policy, risk, and architecture never drift apart.

1.1 Information Security Policy (Master Policy)

Policy ID	POL-SEC-001	**Owner**	Chief Information Security Officer (CISO)
Approved by	Board Security & Technology Committee	**Effective**	October 2026
Review cycle	Annual, or upon material change	**Applies to**	All employees, contractors, and third parties with access

1.1.1 Purpose

This policy establishes Vantage's commitment to protecting the confidentiality, integrity, and availability of the information it holds on behalf of itself, its customers, and their end users. It defines the mandatory security objectives that all subordinate policies, standards, and procedures must satisfy.

1.1.2 Scope

This policy applies to all information systems, data, personnel, facilities, and third-party relationships that create, process, store, or transmit Vantage information — including production cloud infrastructure, corporate endpoints, source code, and any environment that handles customer or cardholder data.

1.1.3 Security Objectives

1. **Protect regulated data.** Personally identifiable information (PII) and cardholder data must be protected at rest and in transit to a standard consistent with SOC 2, ISO 27001, and PCI DSS v4.0 expectations.
2. **Assume no implicit trust.** Access decisions must be based on verified identity, device posture, and least privilege — never on network location alone (see Section 3).
3. **Detect and respond.** The organization must be able to detect material security events and respond within defined severity-based timeframes (see Section 4).
4. **Manage risk explicitly.** Security decisions must be traceable to the enterprise risk register (Section 2).
5. **Demonstrate compliance.** The organization must maintain evidence sufficient to satisfy independent audit and customer due-diligence requests.

1.1.4 Policy Framework & Hierarchy

Tier	Document type	Examples in this program
1 — Policy	Board-approved mandates	POL-SEC-001 (this document), POL-SEC-002 (Access Control), POL-SEC-003 (Third-Party Risk)
2 — Standard	Mandatory technical/process rules	Data Classification & Handling Standard (STD-SEC-010)
3 — Procedure	Step-by-step operational guidance	Incident Response Plan (Section 4), Change Management runbook
4 — Guideline	Recommended practice	Secure coding guidelines, hardening baselines

1.1.5 Roles and Responsibilities

Role	Security responsibility
Board Security & Technology Committee	Approves policy, accepts residual risk, approves security budget, receives quarterly posture reporting.
Chief Information Security Officer	Owns the program; maintains the risk register; reports posture to the board; accountable for incident response.
Chief Technology Officer	Accountable for secure engineering, patching, and remediation SLAs in production systems.
Engineering Managers	Ensure their teams comply with standards; own remediation of findings in their services.
All Personnel	Comply with policy; complete annual training; report suspected incidents immediately.

1.1.6 Policy Compliance & Exceptions

Compliance is monitored through automated control testing, internal audit, and third-party assessments. Any deviation requires a documented, time-bound exception approved by the CISO and recorded in the risk register with a compensating control. Exceptions are reviewed at least quarterly and expire automatically unless renewed.

> **Traceability**
>
> This master policy anchors the program's top risks: objective 2 addresses **R-01, R-04, R-05, R-11** (identity and network trust); objective 3 addresses **R-12** (detection and response); objective 1 addresses **R-07** (data protection); objective 5 addresses **R-08** (compliance).

1.2 Access Control Policy

Policy ID	POL-SEC-002	**Owner**	IAM Engineer (reporting to CISO)
Supports risk	R-01, R-05, R-10, R-11	**Review cycle**	Annual

1.2.1 Principles

Access is granted on the principles of **least privilege**, **separation of duties**, and **zero standing privilege** for administrative functions. No account may hold more access than the task it performs requires, and no access is granted on the basis of network location.

1.2.2 Mandatory Requirements

1. **Identity-first authentication.** All access to Vantage systems authenticates through the central identity provider (IdP) with single sign-on. Local accounts are prohibited except for documented break-glass use.
2. **Phishing-resistant MFA.** All workforce accounts and all administrative access to production require phishing-resistant multi-factor authentication (FIDO2/WebAuthn). Legacy SMS and push-only MFA are being retired. R-01
3. **Just-in-time privileged access.** Standing production administrator rights are prohibited. Elevated access is requested, approved, and time-boxed (maximum 8 hours), and every session is logged. R-05
4. **Quarterly access reviews.** System owners certify that all access remains necessary. Orphaned and excessive entitlements are removed within 5 business days of identification.
5. **Joiner-mover-leaver automation.** Provisioning and de-provisioning are driven by the HR system of record; termination revokes access within 1 hour.
6. **Service account hygiene.** Non-human identities are inventoried, owned, rotated, and never share credentials with humans. R-10
7. **Device trust.** Access to sensitive systems requires a managed, compliant device; unmanaged devices are denied. R-11

1.2.3 Authentication Standards

Access type	MFA requirement	Session rule
Workforce (email, SaaS, corporate apps)	Phishing-resistant (FIDO2) required	12-hour max session; re-auth for sensitive actions
Production administrative	FIDO2 + JIT approval required	8-hour time-box; full session recording
Customer-facing portal	MFA required for all users	Risk-based step-up authentication
Third-party / vendor	Federated SSO, no shared accounts	Session tied to approved change window
Break-glass	Hardware key + dual approval	Auto-expires in 4 hours; alert on use

1.3 Data Classification & Handling Standard

Standard ID	STD-SEC-010	**Owner**	GRC Analyst
Supports risk	R-04, R-07, R-08	**Review cycle**	Annual

1.3.1 Classification Tiers

Tier	Definition	Handling requirements
Restricted	Regulated data: PII, cardholder data, authentication secrets, customer financial records.	Encrypted at rest (AES-256) and in transit (TLS 1.2+); access via least privilege; tokenized where feasible; DLP-monitored; no external sharing.
Confidential	Internal business data: source code, contracts, financials, security configurations.	Encrypted at rest; access on a need-to-know basis; approved collaboration tools only.
Internal	Operational data not intended for public release.	Standard access controls; no special encryption beyond platform defaults.
Public	Marketing, published documentation.	No handling restrictions; integrity controls only.

1.3.2 Data Lifecycle Controls

Restricted data is subject to a documented lifecycle: **collection** (minimization and lawful basis), **storage** (encryption and residency), **use** (least privilege and monitoring), **sharing** (contractual controls and tokenization), **retention** (defined schedules), and **disposal** (cryptographic erasure and certificate of destruction). Data that has no assigned owner is treated as Restricted until classified.

> **Design link**
>
> This standard is the policy basis for the data-protection controls in the Zero Trust architecture (Section 3.6) — specifically tokenization, DLP, and encryption-in-transit requirements that mitigate **R-07** (data exfiltration) and **R-04** (cloud misconfiguration).

1.4 Third-Party Risk Management Policy

Policy ID	POL-SEC-003	**Owner**	GRC Analyst
Supports risk	R-02, R-08, R-13	**Review cycle**	Annual

1.4.1 Purpose

Vantage depends on dozens of SaaS vendors, cloud providers, and subprocessors. This policy ensures that third-party risk is assessed, contracted, and monitored proportionate to the data and access each vendor receives — closing the supply-chain exposure identified as **R-02**.

1.4.2 Vendor Tiering & Due Diligence

Tier	Criteria	Due diligence required
Tier 1 — Critical	Processes Restricted data or has production access	SOC 2 Type II or ISO 27001 required; annual reassessment; security addendum; right-to-audit; breach notification ≤ 24h; named security contact.
Tier 2 — Important	Processes Confidential data; no production access	Completed security questionnaire; evidence of a security program; annual review.
Tier 3 — Standard	No sensitive data; low integration	Self-attestation; standard terms; review every 2 years.

1.4.3 Ongoing Monitoring

Vantage maintains a live inventory of vendors and their data access, continuously monitors Tier 1 vendors for breach disclosures and certificate/domain changes, and requires that any vendor with production access be covered by our own incident response process (Section 4.7). Concentration risk — where multiple critical services depend on one provider — is tracked as a register item.

> **Why this matters here**
>
> A vendor breach in Q1 2026 (a SaaS analytics provider) is the direct trigger for the elevated rating on **R-02** and the reason the board briefing names supply-chain compromise as a top risk.

1.5 Security Governance Structure & Roles

Governance only works if accountability is named and cadence is fixed. Vantage operates a three-layer governance model.

Body	Cadence	Mandate
Board Security & Technology Committee	Quarterly	Oversees security strategy and risk appetite; approves policy and budget; accepts residual risk.
Security Steering Committee	Monthly	Cross-functional (CISO, CTO, CIO, Legal, Compliance, Product); prioritizes remediation and reviews the risk register.
Security Operations & Engineering	Weekly	Executes controls, triages findings, runs incident readiness, and reports metrics.

1.5.1 Security Team Composition (current, October 2026)

Role	FTE	Primary focus
Chief Information Security Officer	1	Program ownership, board reporting, risk acceptance.
IAM Engineer	1	Identity, SSO, MFA, privileged access management.
Security Engineer (Cloud)	1	Cloud security posture, infrastructure hardening, Zero Trust build.
Security Engineer (AppSec)	1	Secure SDLC, API security, vulnerability management.
Detection Engineer	1	SIEM content, detection tuning, MDR coordination.
Security Analyst	1	Alert triage, incident coordination, on-call rotation.
GRC Analyst	1	Policy, risk register, audit, vendor risk.

Total in-house security headcount: **7 (1 CISO + 6 practitioners)**. The team does not operate a 24×7 in-house SOC; after-hours coverage is delivered by a managed detection and response (MDR) partner plus an on-call rotation (see Section 4.2). This is a deliberate, funded design choice — not a gap — and the roadmap (Section 6) preserves it while adding capacity.

1.5.2 Key Governance Metrics Reported to the Board

Metric	Current	Target (FY27)
High risks open in register	6	≤ 2
Phishing-resistant MFA coverage (workforce)	78%	100%
Endpoint EDR coverage	95%	100%
Critical vulnerabilities remediated ≤ 15 days	82%	98%
Mean time to detect (MTTD), high severity	~6 hours	≤ 1 hour
Annual security awareness completion	94%	100%

SECTION 2

Enterprise Risk Register

The single source of truth for the program — fifteen scored risks that give governance, architecture, response, and funding a shared vocabulary.

Every other section of this portfolio points back to this register. When the architecture removes implicit network trust, it is mitigating a specific risk ID. When the incident response plan assumes a forensic retainer is on standby, it is relying on a control that exists because a risk ID required it. When the board briefing asks for money, it names the risk IDs that money closes. The register is therefore not a compliance artifact filed away for auditors — it is the operating spine of the program.

2.1 Methodology

Risks are identified through threat modeling, incident post-mortems, audit findings, vendor assessments, and industry threat intelligence. Each risk is scored on a 5×5 likelihood × impact matrix, owned by a named accountable executive, and reviewed at least quarterly by the Security Steering Committee. Scores reflect **inherent** exposure given current controls; residual exposure after planned treatment is tracked separately.

Likelihood scale

5	Almost certain (multiple times/year)
4	Likely (annual)
3	Possible (every 1–3 years)
2	Unlikely (every 3–5 years)
1	Rare (> 5 years)

Impact scale

5	Severe — regulatory action, >$5M, existential
4	Major — customer loss, $1–5M, material downtime
3	Moderate — $250K–1M, contained disruption
2	Minor — <$250K, limited impact
1	Negligible — no material impact

Rating bands: High score 15–25 · Medium score 8–14 · Low score 1–7.

2.2 The Register (as of October 2026)

ID	Risk statement	Category	L	I	Score	Rating	Accountable owner
R-01	Phishing or credential compromise enables account takeover of workforce or customer accounts.	Identity	4	4	16	High	CISO
R-02	Compromise of a third-party vendor or software supply chain exposes Vantage or customer data.	Supply chain	3	5	15	High	GRC Analyst / CISO
R-03	Ransomware or destructive malware on corporate endpoints or cloud workloads halts operations.	Malware	3	4	12	Medium	Security Engineer (Cloud)
R-04	Cloud misconfiguration (storage, IAM, network) exposes regulated data or enables lateral movement.	Cloud	4	4	16	High	Security Engineer (Cloud)

ID	Risk statement	Category	L	I	Score	Rating	Accountable owner
R-05	Insider threat or misuse of privileged access leads to data theft or sabotage.	Insider	2	5	10	Medium	IAM Engineer
R-06	Broken access control or abuse of public APIs allows unauthorized data access.	Application	3	4	12	Medium	Security Engineer (AppSec)
R-07	Exfiltration of PII or cardholder data results in regulatory penalty, customer loss, and reputational harm.	Data	3	5	15	High	CISO
R-08	Failure to maintain SOC 2 / ISO 27001 / PCI DSS compliance blocks enterprise deals or triggers findings.	Compliance	3	4	12	Medium	GRC Analyst
R-09	DDoS or availability failure of the platform breaches customer SLAs.	Availability	3	3	9	Medium	CTO
R-10	Secrets sprawl (hardcoded credentials, exposed keys) enables unauthorized system access.	Identity / Dev	3	4	12	Medium	Security Engineer (AppSec)
R-11	Shadow IT or unmanaged devices bypass security controls and introduce unmonitored exposure.	Asset mgmt	2	3	6	Low	IAM Engineer
R-12	Inadequate detection and response capability allows a breach to persist undetected (long MTTD/MTTR).	Detection / IR	4	4	16	High	CISO
R-13	Business email compromise or payment fraud diverts funds or triggers unauthorized transactions.	Fraud	3	4	12	Medium	CFO / CISO
R-14	Exploitation of an unpatched vulnerability in production or third-party software leads to compromise.	Vulnerability	4	4	16	High	CTO
R-15	Key-person dependency or security skills gap leaves critical controls unmaintained.	People	2	3	6	Low	CISO

Six risks are rated High: R-01, R-02, R-04, R-07, R-12, R-14. These are the risks carried into the board briefing (Section 5) and the risks the FY27 roadmap (Section 6) is explicitly funded to reduce.

2.3 Risk Heat Map

Impact ↓ / Likelihood →	1 — Rare	2 — Unlikely	3 — Possible	4 — Likely	5 — Almost certain
5 — Severe		R-05	R-02, R-07		
4 — Major			R-03, R-06 R-08, R-10, R-13	R-01, R-04 R-12, R-14	
3 — Moderate		R-11, R-15	R-09		
2 — Minor					
1 — Negligible					

The upper-right quadrant (High band) concentrates the program's attention: identity (R-01), supply chain (R-02), cloud (R-04), data (R-07), detection (R-12), and vulnerability management (R-14).

2.4 Treatment Plans

Each High and Medium risk carries a treatment plan with an owner, a target date, and a link to the architecture or roadmap item that delivers the mitigation. Low risks are accepted and monitored.

ID	Existing controls today	Planned treatment (FY27)	Delivered by	Target
R-01	SSO, push MFA (78% phishing-resistant), awareness training, email filtering.	Complete FIDO2 rollout to 100%; conditional access; number-matching MFA; simulated-phishing program.	Section 3.2 (Identity); Roadmap Q1–Q2	Q2 FY27
R-02	Vendor tiering policy, annual Tier-1 reassessment, contract clauses.	Continuous vendor monitoring; SBOM ingestion; expansion of right-to-audit; fourth-party mapping.	Section 3.7; Roadmap Q3–Q4	Q4 FY27
R-03	EDR on 95% endpoints, email filtering, immutable backups.	100% EDR; ransomware-specific playbook (Section 4.5); backup restoration testing.	Section 4.5; Roadmap Q1	Q1 FY27
R-04	AWS Config rules, quarterly manual review, IaC scanning.	CSPM deployment; policy-as-code guardrails; automated drift remediation.	Section 3.5; Roadmap Q1–Q2	Q2 FY27
R-05	Least privilege, quarterly access reviews, PAM pilot.	Full JIT privileged access; session recording; UEBA alerting.	Section 3.3; Roadmap Q2–Q3	Q3 FY27
R-06	API gateway, OAuth2, annual pen test.	Automated API authZ testing in CI/CD; runtime API protection; expanded pen testing.	Section 3.4; Roadmap Q2–Q3	Q3 FY27
R-07	Encryption at rest/in transit, tokenization of card data, partial DLP.	Enterprise DLP; data-access governance; exfiltration alerting; DSAR automation.	Section 3.6; Roadmap Q1–Q3	Q3 FY27
R-08	SOC 2 Type II current; ISO 27001 gap analysis complete.	ISO 27001 certification; PCI DSS v4.0 assessment; unified control evidence library.	Section 6 (Roadmap)	Q2–Q4 FY27
R-09	AWS Shield, CDN, autoscaling, DR region.	DDoS response runbook; load-testing cadence; SLA dashboard.	Roadmap Q3	Q3 FY27
R-10	Partial secrets scanning, code review.	Central secrets manager; pre-commit scanning; automated rotation; CI/CD gating.	Section 3.8; Roadmap Q1–Q2	Q2 FY27
R-11	MDM on managed devices, SSO-only access.	Device-posture checks in conditional access; SaaS discovery.	Section 3.2; Roadmap Q3	Q3 FY27
R-12	MDR partner, SIEM, on-call rotation, v1 playbooks.	SOAR automation; threat-hunting program; MTTD reduction to ≤ 1 hour; third security engineer.	Section 4; Roadmap Q1–Q4	Q4 FY27
R-13				Q2 FY27

ID	Existing controls today	Planned treatment (FY27)	Delivered by	Target
	Email authentication (DMARC), dual approval for payments.	BEC-specific detections; payment-change verification workflow; finance awareness training.	Section 4.6; Roadmap Q2	
R-14	Monthly vulnerability scans, patch SLAs, dependency scanning.	Continuous scanning; risk-based patch SLAs; internet-facing attack-surface management.	Section 3.9; Roadmap Q1–Q2	Q2 FY27
R-15	Cross-training, documented runbooks.	Third security engineer hire; expanded cross-training; managed-service coverage for key roles.	Roadmap Q2	Q2 FY27

Risk appetite statement

Vantage accepts **Low** residual risk without further investment, tolerates **Medium** residual risk under active monitoring, and does not accept **High** residual risk beyond a defined remediation window. The FY27 roadmap exists to move all six High risks to a Medium or lower residual rating within the fiscal year.

SECTION 3

Zero Trust Architecture

How Vantage defends — removing implicit network trust and making every access decision identity-, device-, and context-aware.

Vantage's architecture is built on a single organizing idea: **no user, device, or workload is trusted by virtue of where it sits on the network.** Trust is never granted once and assumed thereafter; it is evaluated continuously for every request, using verified identity, device posture, and context. This is not a product we buy — it is a set of design decisions, each of which exists to reduce a specific risk in the register. The sections below describe each pillar and, critically, name the risk IDs it addresses.

3.1 Design Principles

1. **Verify explicitly.** Every access request is authenticated and authorized using all available signals — identity, device health, location, and behavior.
2. **Use least privilege.** Access is scoped to the minimum necessary and time-boxed; standing privilege is eliminated for administrative functions.
3. **Assume breach.** The architecture assumes an adversary may already be inside; segmentation, encryption, and monitoring are designed to limit blast radius and shorten dwell time.
4. **Never trust the network.** The corporate network is treated as hostile; the same controls apply whether a request originates from the office, home, or a public network.
5. **Make decisions traceable.** Every control maps to a risk ID, so the architecture can be justified to auditors and the board.

3.2 Pillar 1 — Identity R-01 R-11

Identity is the new perimeter. All workforce and customer access flows through a central identity provider with single sign-on, and the strength of authentication scales with the sensitivity of the resource.

- **Phishing-resistant MFA (FIDO2/WebAuthn)** is mandatory for workforce and administrative access; push-only and SMS factors are being retired. This directly attacks the credential-phishing vector behind **R-01**.
- **Conditional access** evaluates device compliance, location, and risk score before granting a session; unmanaged devices are denied access to Restricted data, mitigating **R-11**.
- **Continuous evaluation** re-assesses sessions on risk signals (impossible travel, token theft indicators) rather than trusting a session for its full lifetime.

3.3 Pillar 2 — Devices & Privileged Access R-05

Endpoints are inventoried, hardened, and continuously assessed for compliance. Administrative access to production is never standing.

- **Endpoint detection and response (EDR)** is deployed on 95% of endpoints today, moving to 100%, providing telemetry that feeds detection (Section 4).
- **Just-in-time (JIT) privileged access** replaces standing admin rights: elevation is requested, approved, time-boxed to a maximum of 8 hours, and fully session-recorded. This is the primary control against **R-05** (privileged misuse).
- **Break-glass accounts** are hardware-key protected, dual-approved, auto-expiring, and generate immediate alerts on use.

3.4 Pillar 3 — Application & API R-06

Vantage is an API-first platform, so application-layer access control is a first-class concern.

- **Central API gateway** enforces authentication, rate limiting, and schema validation on every public endpoint.
- **Object-level authorization** is tested automatically in CI/CD to catch broken access control before release — the root cause class behind **R-06**.
- **Secure SDLC** integrates static analysis, dependency scanning, and IaC scanning into every pipeline; no build reaches production without passing security gates.

3.5 Pillar 4 — Network & Cloud R-04

The network is segmented and the cloud is continuously checked against a hardened baseline.

- **Microsegmentation** separates production, corporate, and development environments; east-west traffic is denied by default.
- **Zero Trust Network Access (ZTNA)** replaces the legacy VPN, granting per-application access rather than broad network reach.
- **Cloud security posture management (CSPM)** continuously detects misconfiguration (open storage, over-permissive IAM, exposed services) and drives automated remediation — the core control for **R-04**.
- **Policy-as-code guardrails** prevent non-compliant infrastructure from being deployed in the first place.

3.6 Pillar 5 — Data R-07

Data protection follows the classification standard (Section 1.3) and assumes the perimeter will eventually be crossed.

- **Encryption** of Restricted data at rest (AES-256) and in transit (TLS 1.2+), with keys managed in a dedicated key service.
- **Tokenization** of cardholder data so that production systems never store raw PANs.
- **Enterprise DLP** and data-access governance detect and alert on anomalous exfiltration patterns — the detection layer for **R-07**.

3.7 Pillar 6 — Third-Party & Supply Chain R-02

- **Continuous vendor monitoring** replaces point-in-time annual reviews for Tier-1 vendors.
- **Software bills of materials (SBOM)** are ingested for critical dependencies, enabling rapid impact assessment when an upstream library is compromised.
- **Least-privilege integration** ensures vendors receive scoped, revocable access rather than broad API keys.

3.8 Pillar 7 — Secrets & Developer Security R-10

- **Central secrets manager** with automated rotation replaces hardcoded credentials.
- **Pre-commit and CI scanning** block secrets from entering repositories; leaked keys trigger automatic revocation.
- **Non-human identity inventory** ensures every service account has an owner and a rotation policy.

3.9 Pillar 8 — Vulnerability & Attack-Surface Management R-14

- **Continuous vulnerability scanning** across cloud workloads, containers, and endpoints, replacing monthly point scans.
- **Risk-based patch SLAs**: critical (internet-facing) within 15 days, high within 30, medium within 90.
- **External attack-surface management** continuously discovers exposed assets and unknown internet-facing services.

3.10 Architecture at a Glance

Identity & Access Layer
Central IdP · SSO · FIDO2 phishing-resistant MFA · conditional access · continuous evaluation
R-01 R-11 R-05

Device & Endpoint Layer
EDR (95%→100%) · MDM · device-posture checks · JIT privileged access · session recording
R-05 R-03

Application & API Layer
API gateway · object-level authZ testing · secure SDLC gates · runtime API protection
R-06 R-10

Network & Cloud Layer
Microsegmentation · ZTNA (VPN retired) · CSPM · policy-as-code · default-deny east-west
R-04 R-09

Data Layer
AES-256 at rest · TLS 1.2+ in transit · tokenization · DLP · data-access governance
R-07

Third-Party & Supply-Chain Layer
Continuous vendor monitoring · SBOM ingestion · least-privilege integration
R-02

Visibility, Detection & Response Layer
SIEM · MDR partner · SOAR · threat hunting · IR plan (Section 4)
R-12 R-14

3.11 Current vs. Target State

Pillar	Current state (Oct 2026)	Target state (end FY27)	Risk closed
Identity	SSO everywhere; 78% phishing-resistant MFA	100% FIDO2; conditional access on all Restricted data	R-01, R-11
Privileged access	Least privilege; PAM pilot	Full JIT access; session recording; UEBA	R-05
Application/API	Gateway + annual pen test	Automated authZ testing; runtime protection	R-06
Network/Cloud	Config rules; manual review	CSPM + policy-as-code; automated remediation	R-04

Pillar	Current state (Oct 2026)	Target state (end FY27)	Risk closed
Data	Encryption; tokenization; partial DLP	Enterprise DLP; exfiltration alerting	R-07
Third party	Annual Tier-1 review	Continuous monitoring; SBOM ingestion	R-02
Secrets	Partial scanning	Central secrets manager; auto-rotation	R-10
Vulnerability	Monthly scans	Continuous scanning; attack-surface mgmt	R-14
Detection/IR	MDR + SIEM + on-call	SOAR + threat hunting; MTTD ≤ 1h	R-12

Traceability check

Every pillar above names the register risk IDs it addresses. No architecture control in this section exists without a corresponding risk in Section 2 — and no High risk in Section 2 lacks a corresponding architecture or roadmap treatment.

SECTION 4

Incident Response Plan

How Vantage responds — a NIST SP 800-61-aligned plan that assumes only the capabilities the program actually operates today.

An incident response plan is only credible if it reflects reality. A plan that assumes a 24×7 in-house SOC, a fully automated SOAR platform, or a forensic team on payroll would be fiction — and fiction collapses the first time it meets a real incident. This plan is deliberately grounded: it describes exactly the detection and response capabilities Vantage operates in October 2026, and it flags the capabilities still being built so that no assumption is silently unfunded. Section 6 confirms that every "operational today" claim below is already paid for, and that every future capability is on the roadmap.

4.1 Purpose & Scope

This plan defines how Vantage detects, contains, eradicates, and recovers from security incidents, and how it communicates during them. It applies to all production systems, corporate systems, and third parties with access to Vantage data. It is aligned to **NIST SP 800-61** (Computer Security Incident Handling Guide) and supports the detection/response objective of the master policy (Section 1.1) and risk **R-12**.

4.2 Operating Model — What Is Operational Today

Capability	Status	Detail
Managed detection & response (MDR) partner	Operational	Onboarded Q4 2025. Provides 24×7 monitoring and first-line triage of EDR, cloud, and identity telemetry.
SIEM	Operational	Cloud-native SIEM ingesting identity, endpoint, cloud, and application logs.
EDR	Operational	Deployed on 95% of endpoints (target 100% by Q1 FY27).
Forensic retainer	Operational	Signed Q1 2026 with an external digital-forensics and incident-response (DFIR) firm; guaranteed response within 4 hours of engagement.
On-call rotation	Operational	Security analyst on-call outside business hours; MDR escalates to on-call. **This is a rotation, not a 24×7 in-house SOC.**
Core playbooks (v1)	Operational	Phishing, ransomware, and data-breach playbooks are documented and rehearsed.
SOAR automation	In build	Not yet operational. Playbook steps are executed **manually** by the on-call analyst until SOAR phase 1 lands (Roadmap Q3 FY27).
Dedicated threat hunting	In build	Not yet operational; delivered in FY27 alongside the third security engineer hire (Roadmap Q1–Q2 FY27).

Consistency guardrail

This plan does **not** assume SOAR automation or a dedicated threat-hunting team, because neither is operational today. Where automation would normally apply, the plan specifies manual execution. The FY27 roadmap (Section 6) funds both capabilities; until they are live, this document describes the manual fallback.

4.3 Severity Classification

Severity	Definition	Response target	Escalation
SEV-1	Confirmed breach of Restricted data, active ransomware, or platform-wide outage.	Acknowledge ≤ 15 min; contain ≤ 1 hr	CISO, CEO, Legal, Board Chair immediately
SEV-2	Confirmed compromise of a system or account without confirmed data loss.	Acknowledge ≤ 30 min; contain ≤ 4 hr	CISO, CTO, Legal
SEV-3	Suspected compromise or contained malware; limited impact.	Acknowledge ≤ 2 hr; contain ≤ 24 hr	Security lead, affected system owner
SEV-4	Policy violation, low-risk alert, or unsuccessful attack.	Triage ≤ 1 business day	Security analyst

4.4 Incident Response Lifecycle (NIST SP 800-61)

Phase	Key activities
1. Preparation	Maintain playbooks, run quarterly tabletop exercises, keep the forensic retainer current, ensure EDR/SIEM coverage, and train the on-call rotation.
2. Detection & Analysis	MDR and SIEM generate alerts; the on-call analyst validates, scopes, and assigns severity. Indicators are enriched with threat intelligence before escalation.
3. Containment	Isolate affected hosts, revoke credentials/tokens, and block malicious infrastructure. Short-term containment first, then a longer-term strategy to preserve evidence.
4. Eradication	Remove adversary presence, patch the exploited vulnerability, and eliminate persistence mechanisms. The DFIR retainer is engaged for SEV-1/SEV-2.
5. Recovery	Restore systems from known-good backups, validate integrity, and monitor closely for re-infection before returning to normal operations.
6. Post-Incident Activity	Conduct a blameless post-mortem within 10 business days, capture lessons learned, update playbooks and the risk register, and report metrics to the Steering Committee.

4.5 Playbooks

Playbook	Addresses	Trigger & first actions
Phishing / account takeover	R-01	Reported or detected phishing → quarantine message, revoke sessions, force credential reset, hunt for related sign-ins. (Manual steps today; SOAR-assisted in FY27.)
Ransomware / destructive malware	R-03	EDR detection → isolate endpoint, disable affected accounts, verify backup integrity, engage DFIR retainer. *Backup restoration testing is added in Roadmap Q1.*
Data breach / exfiltration	R-07	DLP or anomalous-egress alert → contain, preserve evidence, determine data scope, engage Legal for notification analysis.
Cloud misconfiguration exposure	R-04	CSPM finding or report → restrict access, rotate exposed credentials, assess whether data was accessed, remediate the baseline.

Playbook	Addresses	Trigger & first actions
Business email compromise / fraud	R-13	Suspicious payment change or wire request → freeze transaction, verify out-of-band, notify Finance and bank.
Third-party breach	R-02	Vendor notification → assess data exposure, revoke vendor access, coordinate joint response under contract terms.

4.6 Roles & Responsibilities (RACI summary)

Function	Responsibility during an incident
Incident Commander (CISO or delegate)	Owns the incident end-to-end; makes containment and escalation decisions; single point of accountability.
Security Analyst (on-call)	First responder; triage, scoping, and execution of playbook steps (manual until SOAR is live).
MDR Partner	24×7 monitoring and first-line triage; escalates confirmed incidents to on-call.
DFIR Retainer	Deep forensics and root-cause analysis for SEV-1/SEV-2.
Engineering / SRE	System isolation, recovery, and remediation.
Legal & Compliance	Regulatory notification analysis, privilege, and customer/regulator communications.
Communications	Internal and external messaging, coordinated with Legal.

4.7 Communications & Notification

Vantage maintains a documented notification matrix. Material incidents trigger internal escalation to the CISO and CEO, and — where Restricted data is implicated — Legal assesses obligations to customers, regulators, and affected individuals. Contractual breach-notification clauses (Section 1.4) require Tier-1 vendors to notify Vantage within 24 hours. Regulatory and customer notification timelines are tracked against the requirements of SOC 2, PCI DSS, and applicable state privacy laws (R-08).

4.8 Metrics

Metric	Current	FY27 target
Mean time to detect (MTTD), high severity	~6 hours	≤ 1 hour
Mean time to respond (MTTR), high severity	~24 hours	≤ 8 hours
Playbook coverage of top risks	6 of 6 High/Medium	Maintained
Tabletop exercises per year	2	4
Post-mortems completed ≤ 10 business days	100%	100%

SECTION 5

Board Briefing

The security posture, the top risks, and the FY27 investment ask — presented for the Board Security & Technology Committee.

Meeting: Board Security & Technology Committee · **Date:** November 2026 · **Presenter:** Chief Information Security Officer · **Decision requested:** Approve FY27 security investment of $1.42M and accept the residual-risk position described below.

5.1 The Bottom Line

Vantage's security program is maturing and defensible. We hold a current SOC 2 Type II report, we have moved the majority of our endpoints and identity estate under modern controls, and we have a funded forensic retainer on standby. The program is not, however, finished. Six risks remain rated **High**, and the binding constraint on reducing them is **detection and response capacity** — our ability to see and act on threats quickly — not the purchase of additional tools. The FY27 plan asks the Committee to fund a targeted, evidence-based set of investments that close the six High risks, achieve ISO 27001 certification, and advance us toward PCI DSS v4.0 alignment.

5.2 Posture Snapshot

SOC 2 Type II	**Current**	**Endpoint EDR**	95% → 100%
ISO 27001	**In progress**	**MTTD (high severity)**	~6h → ≤1h
PCI DSS v4.0	**Roadmap**	**Security team**	7 FTE (1 CISO + 6)
High risks open	6	**Security spend (% revenue)**	~3.1% → ~4.6%
Phishing-resistant MFA	78% → 100%	**ARR protected**	$92M

5.3 Top Risks the Board Should Track

These six risks are the program's High-rated exposures. Each is drawn directly from the enterprise risk register (Section 2) and each has a named owner, an existing control set, and a funded FY27 treatment.

ID	Risk	Business impact	Why it matters now	FY27 mitigation
R-01	Phishing & credential compromise	Account takeover; fraud	Phishing remains the top initial-access vector industry-wide; 22% of workforce still lacks phishing-resistant MFA.	Complete FIDO2 rollout; conditional access.
R-02	Third-party / supply-chain breach	Customer data exposure	A vendor breach in Q1 2026 showed our exposure to partners we do not control.	Continuous vendor monitoring; SBOM.
R-04	Cloud misconfiguration			

ID	Risk	Business impact	Why it matters now	FY27 mitigation
		Data exposure; lateral movement	Misconfiguration is the leading cause of cloud data exposure; our review is still partly manual.	CSPM; policy-as-code.
R-07	Data exfiltration of regulated data	Regulatory penalty; customer loss	We process PII and tokenized card data on behalf of regulated institutions.	Enterprise DLP; exfiltration alerting.
R-12	Inadequate detection & response	Prolonged breach; higher cost	~6-hour MTTD is above our target; dwell time drives breach cost.	SOAR; threat hunting; 3rd engineer.
R-14	Unpatched vulnerability exploitation	System compromise	Internet-facing assets are attacked continuously; scanning is still monthly.	Continuous scanning; risk-based SLAs.

All six IDs appear in the enterprise risk register (Section 2.2). No risk is named in this briefing that the register does not contain.

5.4 What We Are Asking For — FY27 Investment ($1.42M)

Investment	Amount	Risk addressed
Third security engineer + threat-hunting capability	$280K	R-12, R-15
SOAR platform & implementation	$180K	R-12
CSPM & cloud security tooling	$150K	R-04
ISO 27001 certification & audit	$140K	R-08
Enterprise DLP	$120K	R-07
PCI DSS v4.0 assessment	$120K	R-08
Continuous vendor monitoring & SBOM	$110K	R-02
Secrets management platform	$90K	R-10
Penetration-testing expansion	$80K	R-06, R-14
Security awareness & phishing-simulation upgrade	$50K	R-01, R-13
Contingency	$100K	—
Total FY27 request	**$1.42M**	

5.5 Why This Is the Right Level of Spend

Vantage's security spend is approximately 3.1% of revenue today; the FY27 plan raises it to roughly 4.6%, in line with peer fintechs of our size and regulatory exposure. The plan prioritizes **capability over tooling**: the single largest line item is a person, because

detection and response capacity — not another dashboard — is what shortens the time an attacker can operate undetected. Every dollar requested maps to a named risk, and every named risk maps to a business consequence the Committee already understands: customer trust, regulatory standing, and the ability to win enterprise deals that require ISO 27001 and PCI DSS assurance.

5.6 Decisions Requested

1. **Approve** the FY27 security investment of $1.42M as itemized in Section 5.4.
2. **Accept** the current residual-risk position, acknowledging six High risks under active treatment.
3. **Endorse** ISO 27001 certification as an FY27 corporate objective and PCI DSS v4.0 alignment as an FY27–FY28 objective.
4. **Note** the detection-and-response capacity constraint (R-12) as the program's single most important dependency.

> **One-line ask**
>
> Fund $1.42M in FY27 to close six named High risks, certify ISO 27001, and add the detection capacity that makes the rest of the program effective.

SECTION 6

FY27 Compliance & Capability Roadmap

The funding and delivery timeline that makes every "operational today" claim in the incident response plan true — and every future capability real.

The roadmap is where the portfolio proves it is one program rather than four documents. It takes the risks in the register, the controls in the architecture, and the capabilities the incident response plan assumes, and sequences them into a funded twelve-month plan. Critically, it distinguishes what is **already operational** (and therefore safe for the IR plan to rely on) from what is **still being built** (and therefore must not be assumed). FY27 runs January–December 2027.

6.1 Baseline — Operational Before FY27

Capability	Since	Status
SOC 2 Type II	2024	Current
MDR partner (24×7 monitoring)	Q4 2025	Operational
SIEM	2025	Operational
EDR (95% coverage)	2025	Operational
Forensic retainer (DFIR firm)	Q1 2026	Operational
On-call rotation + core playbooks (v1)	2025–2026	Operational
SSO + partial phishing-resistant MFA (78%)	2025	Operational

6.2 FY27 Quarterly Plan

Quarter	Compliance milestones	Security capability milestones	Risks advanced
Q1 FY27 Jan–Mar	ISO 27001 Stage 1 readiness assessment; control-evidence library stood up.	100% FIDO2 MFA; 100% EDR; ransomware playbook + backup-restoration testing; CSPM deployment begins; secrets-manager deployment begins; continuous vulnerability scanning begins; **third security engineer hired**.	R-01, R-03, R-04, R-10, R-14, R-12
Q2 FY27 Apr–Jun	**ISO 27001 Stage 2 audit → certification**; PCI DSS v4.0 scoping begins.	CSPM complete + policy-as-code; secrets manager complete with auto-rotation; JIT privileged access expanded; API authZ testing in CI/CD; **threat hunting begins**; BEC detections; continuous scanning complete.	R-04, R-10, R-05, R-06, R-12, R-13
Q3 FY27 Jul–Sep	ISO 27001 surveillance planning; PCI DSS v4.0 gap remediation.	**SOAR phase 1 live** (manual playbook steps automated); enterprise DLP deployment; UEBA alerting; continuous vendor monitoring + SBOM	R-12, R-07, R-02, R-09, R-11

Quarter	Compliance milestones	Security capability milestones	Risks advanced
		ingestion; DDoS runbook; device-posture checks in conditional access.	
Q4 FY27 Oct–Dec	**PCI DSS v4.0 assessment**; annual policy review; ISO 27001 first surveillance audit.	SOAR phase 2; threat-hunting program mature (**MTTD ≤ 1 hour**); vendor monitoring fully operational; annual program review.	R-12, R-02, R-08, R-14

6.3 Capability Funding Alignment

This table exists to answer one reviewer question: *is every capability the incident response plan relies on actually funded?*

IR plan assumption (Section 4)	Funding source	Status
MDR partner provides 24×7 monitoring	Existing operating budget	**Funded & live**
Forensic retainer on standby	Existing operating budget	**Funded & live**
SIEM + EDR telemetry	Existing operating budget	**Funded & live**
On-call rotation (not 24×7 in-house SOC)	Existing headcount	**Funded & live**
SOAR automation (explicitly *not* assumed today)	FY27 ask — $180K	**Funded Q3 FY27**
Dedicated threat hunting (explicitly *not* assumed today)	FY27 ask — $280K (engineer)	**Funded Q1–Q2 FY27**

The consistency guarantee

The IR plan (Section 4.2) assumes only the four capabilities marked *Funded & live*. The two capabilities it explicitly does *not* assume (SOAR and threat hunting) are precisely the ones the roadmap funds in FY27. There is no capability the IR plan leans on that the roadmap has not paid for — and no capability the roadmap funds that the IR plan quietly assumes already exists.

SECTION 7

Consistency & Traceability Review

The verification pass that proves the four artifacts are one program, not four exercises.

Before this portfolio was finalized, it was reviewed for internal consistency — the single most important quality check for a document that claims to describe one coherent security function. Three specific checks were performed, mirroring the way a reviewer would test the portfolio: do the risks named in the board briefing match the register, do the architecture decisions trace back to those same risks, and does the compliance roadmap align with what the incident response plan assumes is operationally in place today?

7.1 Check 1 — Board briefing risks ⊆ Risk register

Result: PASS. The board briefing (Section 5.3) names exactly six risks — R-01, R-02, R-04, R-07, R-12, R-14 — and all six appear in the register (Section 2.2) with the same ratings and owners. No risk is named in the briefing that the register does not contain, and no High-rated register risk is omitted from the briefing.

7.2 Check 2 — Architecture decisions trace to register risks

Result: PASS. Every pillar of the Zero Trust architecture (Section 3) names the risk ID(s) it mitigates, and every High and Medium risk in the register has at least one corresponding architecture control or roadmap treatment. The mapping is shown below.

Risk	Rating	Architecture control (Sec. 3)	IR playbook (Sec. 4)	Roadmap (Sec. 6)	Board mention
R-01	High	3.2 Identity — FIDO2, conditional access	4.5 Phishing/ATO	Q1 FIDO2 100%	5.3 ✓
R-02	High	3.7 Third-party — continuous monitoring, SBOM	4.5 Third-party breach	Q3 vendor monitoring	5.3 ✓
R-03	Medium	3.3 Devices — EDR	4.5 Ransomware	Q1 backup testing	—
R-04	High	3.5 Network/Cloud — CSPM, policy-as-code	4.5 Cloud misconfig	Q1–Q2 CSPM	5.3 ✓
R-05	Medium	3.3 Devices — JIT privileged access	4.5 (containment)	Q2 JIT expansion	—
R-06	Medium	3.4 App/API — object-level authZ testing	4.5 (containment)	Q2 API testing	—
R-07	High	3.6 Data — DLP, tokenization, encryption	4.5 Data breach	Q3 enterprise DLP	5.3 ✓
R-08	Medium	1.3 Data standard; governance	4.7 Notification	Q2 ISO; Q4 PCI	5.6 ✓
R-09	Medium	3.5 Network — segmentation, Shield	4.5 (availability)	Q3 DDoS runbook	—

Risk	Rating	Architecture control (Sec. 3)	IR playbook (Sec. 4)	Roadmap (Sec. 6)	Board mention
R-10	Medium	3.8 Secrets — central manager	4.5 (containment)	Q1–Q2 secrets mgr	5.4 ✓
R-11	Low	3.2 Identity — device posture	—	Q3 posture checks	—
R-12	High	3.10 Detection layer — SIEM, MDR	4.4 lifecycle; 4.8 metrics	Q3 SOAR; Q4 hunting	5.3, 5.6 ✓
R-13	Medium	3.2 Identity; 3.4 App	4.5 BEC/fraud	Q2 BEC detections	—
R-14	High	3.9 Vulnerability — continuous scanning	4.5 (eradication)	Q1–Q2 scanning	5.3 ✓
R-15	Low	1.5 Governance — cross-training	—	Q2 3rd engineer	5.4 ✓

7.3 Check 3 — Roadmap timeline vs. IR plan assumptions

Result: PASS. The incident response plan (Section 4.2) assumes four capabilities are operational today — MDR 24×7 monitoring, SIEM/EDR telemetry, the forensic retainer, and the on-call rotation — and all four are in the pre-FY27 baseline (Section 6.1), funded by the existing operating budget. The plan explicitly does *not* assume SOAR automation or a dedicated threat-hunting team; those two capabilities are funded by the FY27 roadmap (Section 6.3) and are the exact items the plan flags as "in build." **There is no capability the IR plan assumes that the roadmap has not funded.**

> **Reviewer's summary**
>
> The three consistency checks all pass. The board briefing cites only register risks; the architecture traces to those risks; and the IR plan's operational assumptions are fully funded while its future capabilities are explicitly roadmap-funded. A reviewer can follow any claim in this portfolio back to its source without finding a contradiction.

APPENDIX A

Control Mapping — NIST CSF 2.0

A crosswalk showing how the program's controls map to the six NIST Cybersecurity Framework 2.0 functions.

This appendix lets an auditor or customer trace Vantage's program to a recognized framework. Each NIST CSF 2.0 function is mapped to the portfolio sections and register risks that implement it.

CSF Function	Representative controls at Vantage	Portfolio reference	Risks
GOVERN (GV)	Board oversight; master policy; risk appetite; roles and responsibilities; third-party policy.	Sections 1.1, 1.4, 1.5	R-08, R-15
IDENTIFY (ID)	Risk register; asset inventory; data classification; vendor inventory; SBOM.	Sections 1.3, 2, 3.7	R-02, R-08
PROTECT (PR)	Phishing-resistant MFA; least privilege; JIT access; encryption; tokenization; microsegmentation; secrets management; secure SDLC.	Sections 3.2–3.8	R-01, R-04, R-05, R-06, R-07, R-10, R-11
DETECT (DE)	SIEM; MDR; EDR; CSPM; DLP; UEBA; continuous vulnerability scanning.	Sections 3.5, 3.9, 4.2–4.4	R-04, R-12, R-14
RESPOND (RS)	IR plan; severity classification; playbooks; forensic retainer; communications and notification.	Section 4	R-01, R-02, R-03, R-07, R-12, R-13
RECOVER (RC)	Immutable backups; DR region; backup-restoration testing; post-incident reviews.	Sections 4.4, 6.2	R-03, R-09

Framework Alignment Summary

Framework / Standard	Current status	Relevance
SOC 2 Type II	**Current**	Core assurance for enterprise customers.
ISO/IEC 27001:2022	**Target Q2 FY27**	International recognition; unlocks EU deals.
PCI DSS v4.0	**Target Q4 FY27**	Required for cardholder-data handling.
NIST CSF 2.0	**Adopted**	Organizing framework for the program.
NIST SP 800-61	**Adopted**	Incident response lifecycle.
NIST SP 800-207 (Zero Trust)	**Adopted**	Zero Trust architecture principles.

APPENDIX B

Glossary

Definitions of the acronyms and terms used throughout this portfolio.

Term	Definition
ATO	Account Takeover — unauthorized access to a user account, typically via stolen credentials.
BEC	Business Email Compromise — fraud in which an attacker impersonates a trusted party to divert funds or data.
CSPM	Cloud Security Posture Management — continuous detection of cloud misconfigurations.
DFIR	Digital Forensics and Incident Response — specialist investigation of security incidents.
DLP	Data Loss Prevention — controls that detect and block unauthorized data movement.
EDR	Endpoint Detection and Response — monitoring and response software on endpoints.
FIDO2 / WebAuthn	Phishing-resistant authentication standards using hardware security keys or platform authenticators.
IAM	Identity and Access Management.
JIT	Just-in-Time access — granting elevated privileges only when needed, for a limited time.
MDR	Managed Detection and Response — an external partner providing 24×7 monitoring and triage.
MTTD / MTTR	Mean Time To Detect / Mean Time To Respond.
PAM	Privileged Access Management.
PII	Personally Identifiable Information.
SBOM	Software Bill of Materials — an inventory of components in a software product.
SIEM	Security Information and Event Management — centralized log aggregation and correlation.
SOAR	Security Orchestration, Automation, and Response — automation of response playbooks.
UEBA	User and Entity Behavior Analytics — detection based on anomalous behavior.
ZTNA	Zero Trust Network Access — per-application access that replaces broad VPN connectivity.

Closing Statement

This portfolio represents the consolidated security program of Vantage Financial Technologies as of October 2026. It is intended to be a living document: the risk register is reviewed quarterly, the architecture and roadmap are updated annually or upon material change, and the incident response plan is exercised at least twice a year. The executive summary at the front of this document will be refreshed with each major revision so that a first-time reader always receives an accurate one-page picture of the program.

Vantage Financial Technologies, Inc. — Information Security Program Portfolio, Version 1.0 — Confidential. Prepared by the Office of the CISO for the Board Security & Technology Committee.